# Work in Progress: Leveraging Large Language Models for Cybersecurity Compliance: A Pilot Study in ISO 27001 Audit Planning

1st Ahmed Salman
*Department of Computer Science*
*University of Oxford*
*Oxford, UK*
*ahmed.salman@cs.ox.ac.uk*

2nd Yara Alsiyat
*Department of Computer Science*
*University of Oxford*
*Oxford, UK*
*yara.alsiyat@wolfson.ox.ac.uk*

3rd Sadie Creese
*Department of Computer Science*
*University of Oxford*
*Oxford, UK*
*sadie.creese@cs.ox.ac.uk*

4th Michael Goldsmith
*Department of Computer Science*
*University of Oxford*
*Oxford, UK*
*michael.goldsmith@worc.ox.ac.uk*

2025 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW) | 979-8-3315-9546-3/25/$31.00 ©2025 IEEE | DOI: 10.1109/EUROSPW67616.2025.00046

***Abstract*—Cybersecurity compliance processes are often subjective and error-prone due to their reliance on manual documentation. This pilot study evaluates the potential of Large Language Models (LLMs) in cybersecurity compliance during the planning phase of ISO 27001 standard. Using a hypothetical telecommunications organization, we evaluated three tasks: Statement of Applicability generation, audit scope definition, and compliance checklist development, assessing Sonnet 3.5, ChatGPT 4o, and Llama 3.1 via ordinal scoring and qualitative factors (e.g., scalability, skill coverage). Sonnet 3.5 consistently outperformed other models across all tasks, though all struggled with completeness and data assimilation. These findings validate LLMs' ability to streamline compliance workflows while highlighting key limitations that must be addressed for practical deployment.**

## 1. Introduction

Cybersecurity compliance is essential for organizational assurance but faces persistent inefficiencies. Prior work [1] highlights three key challenges: a lack of environmental evidence, where documentary audits sometimes overlook real-time network insights (e.g., configuration logs); static approaches, slow to adapt to regulatory or threat changes; and human subjectivity, introducing variability into manual assessments. While automation has been proposed to mitigate these issues, such efforts have struggled with the extensive analysis required for vast, unstructured compliance data. Large Language Models (LLMs), with their ability to process unstructured formats, present a promising solution [1]. This paper presents a pilot study testing this approach within a telecommunications compliance context, focusing on the critical planning and scoping stage that provides a foundation for subsequent compliance steps like fieldwork, analysis, and reporting.

Planning and scoping in compliance activities require precision, domain-specific expertise, and considerable effort. As the foundational phase, effective planning ensures downstream audit accuracy and regulatory alignment, making it a key target for automation. Unlike sectors reliant on cloud providers, telecommunications still maintain complex, on-premises IT systems, offering a compelling testbed for compliance workflows. We adopted ISO 27001, a widely recognized standard across industries, for its structured approach and extensive resources [2]. Figure 1 depicts the general compliance lifecycle [3], presenting planning as the foundational stage evaluated here. To anchor our study, we created HelloPak, a hypothetical Mobile Network Operator (MNO). Figure 2 illustrates HelloPak's network, providing context for our experiments.

We targeted three planning tasks: Statement of Applicability (SoA) generation, audit scope definition, and checklist creation. Initially planned as a purely qualitative evaluation, we incorporated ordinal scoring, common in LLM assessments [4], [5], to rank output quality by relevance and completeness. Additionally, we used qualitative scoring to assess scalability, skill coverage, and change absorption. Unlike prior studies targeting specific compliance steps (e.g., policy analysis [6], [7]), this pilot study explores LLMs across the ISO 27001 planning phase. This dual approach offers practical insights into LLMs' operational utility in cybersecurity compliance workflows. As a novel pilot, it lays the foundation for broader exploration of subsequent stages in the compliance workflows. Next, we outline our methodology to evaluate these tasks and scoring methods in detail.

## 2. Methods

This pilot assesses three LLMs for the compliance planning stage: Sonnet 3.5 [8], Llama 3.1 [9] (both hosted on the Abacus AI platform), and ChatGPT 4o [10] (OpenAI platform), selected for their recency, availability, and benchmarking at the study's outset. Although newer LLMs have since emerged, our focus on operational insights ensures the study's relevance. Using multiple LLMs mitigates bias from any single model's weaknesses, enhancing the robustness of our observations. Access to these LLMs

© 2025, Ahmed Salman. Under license to IEEE.

DOI 10.1109/EuroSPW67616.2025.00046
Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

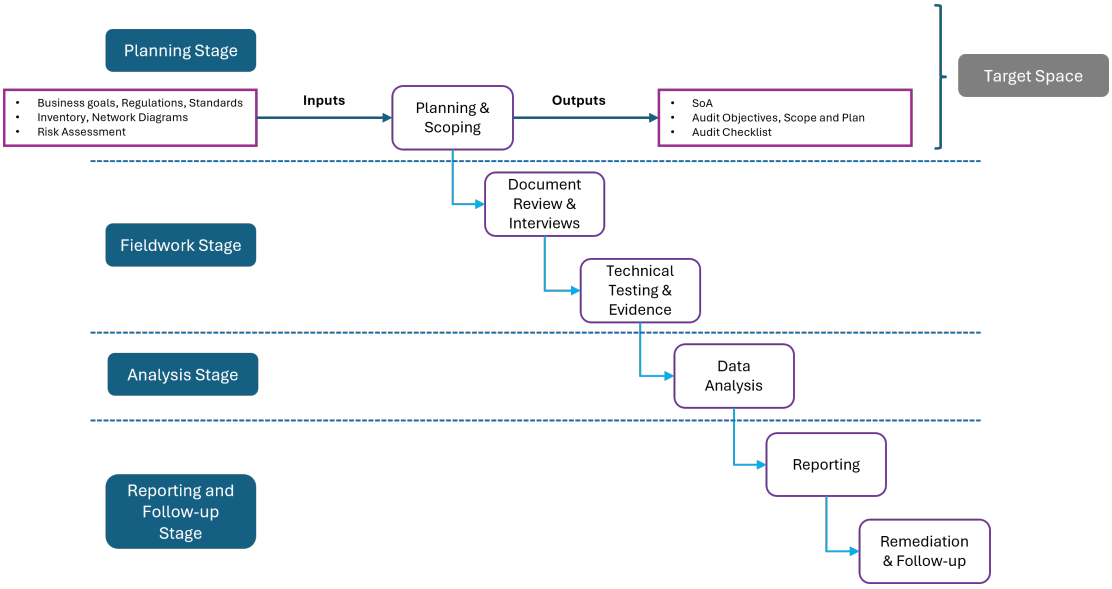


Figure 1. General Compliance Workflow

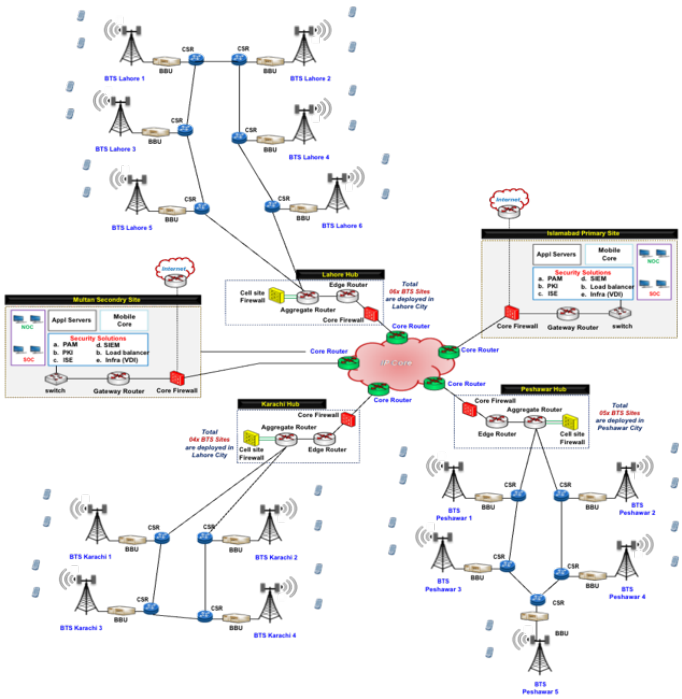

Figure 2. HelloPak Network

was obtained through paid accounts on the OpenAI and Abacus AI platforms.

The experiments utilize HelloPak, a hypothetical Mobile Network Operator (MNO) in its pilot operations. HelloPak's dataset is inspired by real-world telecommunications data, including an asset register (121 assets), a basic risk assessment, and a few policy documents. HelloPak is seeking an initial internal audit to identify gaps and later move towards ISO 27001 certification.

Three evaluation tasks were defined: 1) SoA generation to map organizational context to ISO 27001 clauses; 2) audit objectives, scope, and plan, to establish boundaries and timelines; and 3) audit checklist to produce action items for auditors. For each task, six experiments were conducted—two per LLM—to explore performance variations in non-collaborative (independent prompts) and collaborative (multi-turn) generation. Prompts were crafted with ChatGPT 4o and underwent extensive iteration to enable elaborate, high-quality responses and test the intrinsic capability of LLMs on compliance tasks. Figure 3 illustrates this setup.

We used two categories of evaluation factors to assess LLM performance in the study: 1) Model performance, 2) Usefulness. The "model performance" factors used ordinal scores on a Likert scale (0–3: 0 = poor, 3 = excellent), assessed by human evaluators (authors with relevant domain expertise), to measure Relevance (task alignment), Completeness (coverage of required elements), Inference



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

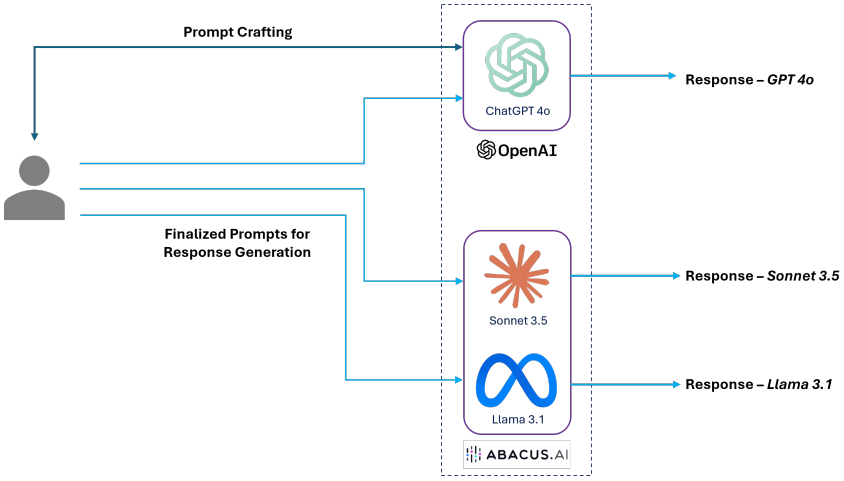


Figure 3. Experimental Setup

Time (response speed), and Hallucinations (factual errors). These factors are well-known in LLM assessments using human evaluation methodology. The "usefulness" factors—Change Absorption, Scalability, and Skill Coverage—provided Yes/No assessments across experiments, judged by practical utility. Results present the outcomes of these evaluations across all tasks.

## 3. Results

As outlined in Methods, 18 experiments evaluated LLMs across the three compliance planning tasks. A summary of the results (Model Performance and Usefulness) is presented in Figure 4 and Table 1 respectively. Detailed scores are presented in Appendix A.

### 3.1. SoA Generation

Statement of Applicability (SoA) is the first step in a cybersecurity compliance audit according to the ISO 27001 standard. The SoA maps an organization's environment to control clauses, typically in a tabular format, and establishes a foundation for subsequent activities.

After experimenting with simple prompts and receiving inadequate outputs, we determined that detailed prompts incorporating organizational details were necessary for these experiments. In our refined prompt, we included organizational details augmented by the network diagram and asset register. Llama 3.1 could not process images and thus received only the asset register, which was converted from CSV to Word format, as this improved data absorption on the platform used. Two sets of experiments were conducted: first, generating a basic SoA based on provided context, and second, altering the context slightly to evaluate the LLMs' ability to identify only the affected control clauses accurately.

**3.1.1. Performance Comparison. Sonnet 3.5** showed the best performance in terms of relevance, with a score of 3 in the first set of experiments, but performed poorly in terms of completeness, with a score of 1. However, it showed strong performance in terms of inference and hallucinations, with scores of 3 and 3, respectively. In the second set, Sonnet 3.5 achieved perfect scores for relevance and completeness, demonstrating strong change absorption capabilities, as it correctly identified all impacted clauses without omissions when the context was altered. Meanwhile, **ChatGPT 4o** performed poorly in the first set, with scores of 1 and 2 for relevance and completeness respectively. However, its performance improved in the second set, achieving scores of 1, 3, and 3 for relevance, completeness, and inference, respectively. **Llama 3.1** showed the least effective performance in the first set, with scores of 1 and 0 for relevance and completeness, respectively, and also had a low score of 2 for inference. However, it outperformed ChatGPT 4o in the second set, achieving perfect scores for both relevance and completeness.

**3.1.2. Insights and Analysis. Data curation** and assimilation were identified as potential issues, particularly with the Abacus AI platform, which exhibited limitations in data absorption and file type compatibility, as indicated by the need to convert the asset register from CSV to Word format for better assimilation. Additionally, **effective prompt** development required significant time and multiple iterations; it was found that specific, structured prompts and fewer reference files yielded better results. Regarding specific model performance, **Sonnet 3.5** demonstrated superior capabilities in terms of stability, comprehension, analysis, summarization, and knowledge of ISO 27001 and telecom concepts. In a real-world environment, Sonnet 3.5's outputs would likely save significant time and provide the skilled analysis required for this activity, although its previously noted completeness issue could play a critical role in real-world scalable applications.

### 3.2. Audit Objectives, Scope, and Plan

This step establishes the framework for a compliance audit. We provided detailed organizational context, alongside the asset register and network diagram reused from the previous activity. Two sets of experiments were conducted: an initial trial with a basic prompt, followed by a slight context alteration to assess its impact on the output.



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

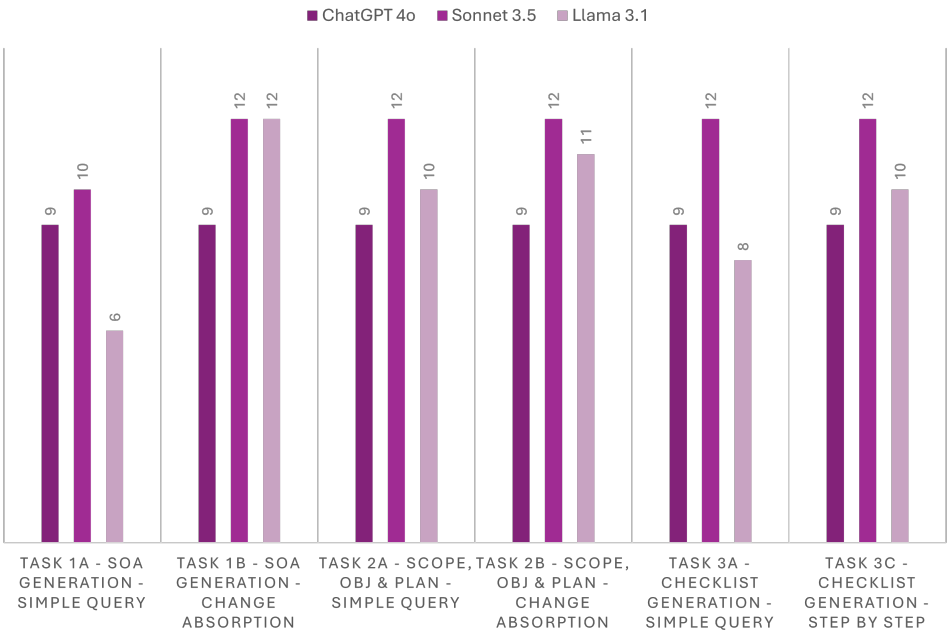


Figure 4. Aggregate Scores - Model Performance

TABLE 1. QUALITATIVE INSIGHTS ON USEFULNESS

| Factors | Observed Results | Remarks |
|---|---|---|
| Change Absorption | Yes | Modification of outputs was observed in all models' responses when prompted with a change in input. |
| Scalability | Needs further study | ChatGPT 4o demonstrated some scalability when prompted with more documents, however rest two models produced data errors potentially due to platform malfunction. Further investigation using newer techniques might be useful in a future study to address this issue. |
| Skill Coverage | Yes | All compliance steps require skill and knowledge of various cybersecurity disciplines, which were handled impressively by the LLMs. |

**3.2.1. Performance Comparison. Sonnet 3.5** achieved scores of 3 and 3 for relevance and completeness, respectively, in both sets of experiments. It demonstrated an excellent to-the-point analysis with pertinent details, along with good assimilation of change. In contrast, **ChatGPT 4o** showed lower performance with scores of 1 and 3 for relevance and completeness in both sets. It exhibited a tendency to go into more detail than necessary, the plan generated was incorrect with respect to the distribution of days, and it also produced some hallucinated timelines. **Llama 3.1** also achieved scores of 3 and 3 for relevance and completeness, respectively, in both sets of experiments; however, the plan it generated was similarly incorrect with respect to the distribution of days.

**3.2.2. Insights and Analysis.** It was observed that **excessive augmenting data** may complicate LLMs' ability to correlate conditions, leading to suboptimal outputs and negatively impacting scalability. In contrast, limited data combined with specific prompts consistently yielded acceptable results. On a positive note, outputs from all LLMs generally **aligned with telecommunications concepts and audit requirements**, saving time in planning and effectively capturing the skills and knowledge needed to define accurate objectives, scope, and a practical plan.

## 3.3. Checklist Generation

We conducted six experiments in two sets to generate audit checklists for an ISO 27001 compliance review. Organizational context was provided in the prompt, augmented with a simple risk register, asset register, and sample checklist questions, all in Word format due to previously observed data assimilation issues with other formats. Instead of a network diagram itself, we used ChatGPT 4o to describe the topology details and this was added to the organizational context in the prompt. Detailed steps were given to the LLMs, specifying how to conduct the activity, prioritize action items, and generate checklists for the top two focus areas to save time.

**3.3.1. Performance Comparison. Sonnet 3.5** consistently performed well, excelling in both the initial experiment and the step-by-step approach with perfect scores across all factors. It also demonstrated strong telecommunications and audit knowledge, providing a well-structured and comprehensive checklist, and consistently outperformed the other models, demonstrating a better understanding of the task and domain knowledge. In contrast, **ChatGPT 4o** initially performed poorly with scores of 2 and 1 for relevance and completeness, failing to correctly analyze the risk register. However, it showed improvement



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

in the step-by-step approach but still produced hallucinated outputs, achieving scores of 2 for both relevance and completeness. **Llama 3.1** also initially struggled with scores of 2 and 1 for relevance and completeness, respectively. However, it showed some improvement in the step-by-step approach, achieving scores of 3 and 2 for relevance and completeness, respectively, and we also observed a better explained output compared to the initial experiment.

**3.3.2. Insights and Analysis. Data assimilation** issues persisted in this compliance step as well, highlighting the need for careful data preparation and format selection. Furthermore, using **prompt engineering** was found to be beneficial for output generation, although highly descriptive prompts were crucial for achieving acceptable results, suggesting potential scalability challenges in complex scenarios. Despite the challenges, where responses were pertinent, we observed **knowledgeable outputs**, offering skill coverage and saving time in audit planning.

## 3.4. Summary of Findings

**3.4.1. Performance Analysis. Sonnet 3.5** consistently outperformed other LLMs, demonstrating superior comprehension, analysis, and domain knowledge across all tasks. It mostly excelled in generating relevant and complete outputs, particularly in generating the Scope, Objectives, and Plan as well as the checklist generation task, where it achieved perfect scores in multiple experiments. Even in the SoA generation task, Sonnet 3.5 correctly identified all impacted clauses when the context was altered, showcasing its strong change absorption capabilities. In comparison, **ChatGPT 4o** showed moderate performance marked by inconsistencies and a tendency to hallucinate. While it improved with more specific guidance, it still struggled with relevance and completeness compared to Sonnet 3.5; for example, in the audit objectives, scope, and plan generation task, ChatGPT 4o produced hallucinated timelines and inaccurate plans. **Llama 3.1** also initially struggled with complex tasks but showed significant improvement with the more specific approach. It demonstrated good knowledge of ISO 27001 and telecommunications concepts but lagged behind Sonnet 3.5 in terms of overall performance, though in the checklist generation task, Llama 3.1 produced a slightly better-explained output with a step-by-step approach after initially struggling.

**3.4.2. Usefulness Analysis.** Regarding **Skill Coverage and Time Saving,** despite the challenges, LLMs demonstrated potential for assisting in compliance tasks by generating relevant outputs, saving time, and offering skill coverage. Sonnet 3.5, in particular, showcased the ability to provide skilled analysis and reduce manual effort in all the tasks. However, **Scalability** remains a concern due to the challenges observed in handling large amounts of data and complex scenarios. Establishing linkages and correlating information was also observed to be a persistent issue; for instance, as noted in SoA generation, all LLMs skipped multiple clauses despite specific prompts and guidance, and in the checklist generation task, highly descriptive prompts were essential, suggesting potential scalability challenges in complex scenarios.

**3.4.3. General Observations.** Effective **Prompt Engineering** was crucial for achieving optimal results. Specific, structured prompts with fewer reference files yielded better outcomes, highlighting the importance of prompt engineering for practical LLM applications in compliance automation; for example, in the checklist generation task, detailed prompts incorporating organizational details were instrumental for achieving adequate outputs. Furthermore, **Data Curation** and assimilation were identified as key factors influencing LLM performance. Well-curated documents in compatible formats improved data absorption and analysis, emphasizing the need for careful data preparation for real-world compliance tasks, as was evident in the SoA generation task where converting the asset register to Word format improved data absorption for Llama 3.1. It was also noted that ChatGPT 4o was more proficient in data ingestion and format support compared to the Abacus AI platform. Moreover, **Hallucinations** were observed, with ChatGPT 4o exhibiting a tendency towards them, particularly in tasks requiring data analysis and interpretation, raising concerns about the reliability of its outputs for critical compliance decisions. Finally, **Analysis Capability** for data analysis and complex scenarios posed challenges for all LLMs; establishing linkages and correlating information was observed to be an issue, often requiring prompt engineering to convey these linkages to the LLM.

# 4. Discussion

This pilot study demonstrates the potential of LLMs to assist in compliance automation while also highlighting critical challenges that must be addressed for their effective adoption. This section discusses the implications of the results and the challenges observed.

The results indicate that **Sonnet 3.5** consistently outperformed other models, showcasing superior comprehension, analysis, and domain knowledge. Its ability to generate relevant and complete outputs, particularly in tasks like checklist generation and SoA generation, highlights its potential as a reliable model for compliance workflows. However, occasional issues with completeness, such as skipping clauses in SoA generation, suggest that even the best-performing models require further refinement to ensure reliability in high-stakes compliance tasks.

**ChatGPT 4o** demonstrated moderate performance but exhibited inconsistencies, including hallucinations and inaccuracies in tasks requiring detailed analysis, such as audit objectives and scope generation. While its performance improved with the step-by-step approach, these limitations raise concerns about its suitability for critical compliance tasks without human oversight. Similarly, **Llama 3.1**, while initially struggling with complex tasks, showed improvement with structured workflows and demonstrated good domain knowledge. However, its reliance on simplified data formats and its lagging performance compared to Sonnet 3.5 suggest that it is less suited for compliance activities.

The study also revealed several broader implications regarding the use of LLMs in compliance automation.



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

Firstly, the capacity of LLMs to save time and provide necessary skill coverage represents a significant advantage, particularly within resource-constrained environments. For example, Sonnet 3.5's outputs across all tasks demonstrated that the required manual effort can be substantially reduced. However, the observed challenges, such as hallucinations, skipped clauses, and scalability issues, underscore the critical need for robust validation mechanisms and human oversight. This oversight is essential to ensure the accuracy and reliability of LLM-generated outputs, as unverified results could introduce significant risks into the compliance process. Consequently, the potential time and effort savings are heavily contingent upon the overhead required to effectively verify these LLM outputs.

**Prompt engineering** emerged as a critical factor influencing LLM performance. Highly descriptive and structured prompts proved essential for achieving acceptable results, particularly for complex tasks such as checklist generation. However, the time-intensive nature of prompt development raises scalability concerns, especially within large-scale compliance workflows involving numerous interconnected documents and regulations. Similarly, **data curation** played a pivotal role in determining output quality. Well-curated documents in compatible formats improved data processing and analysis, as observed in the SoA generation task, where converting the asset register to Word format enhanced Llama 3.1's performance. This highlights that significant upfront effort in both prompt engineering and data preparation represents a practical prerequisite for effectively leveraging LLMs in real-world compliance tasks. These findings underscore the importance of optimizing data preparation and prompt design for real-world applications. The structured prompt approach discussed here has lately been incorporated in many LLMs models as Chain-of-Thought (CoT) prompting [11]. Models such as OpenAI-01, DeepSeek's R1, and Claude Sonnet-3.7 are notable reasoning models that have achieved enhanced results using this approach.

Despite the apparent potential, the study identified significant **scalability challenges** in LLMs. All LLMs struggled to handle large data volume and complex scenarios, such as correlating information across multiple documents. For instance, in SoA generation, even with specific prompts, multiple clauses were skipped, which indicates that current LLMs may not yet be fully equipped to manage the demands of real-world compliance tasks in large organizations, suggesting a need for human oversight. Additionally, hallucinations observed in ChatGPT 4o raise concerns about the **reliability** of LLMs for critical compliance decisions, emphasizing the need for mechanisms to validate and verify outputs. Consequently, while numerous frameworks and Retrieval-Augmented Generation (RAG) techniques [12] (including Graph RAG for correlation [13]) aim to improve data assimilation, attribution, and grounding, these findings underscore that further advancements in reliability are necessary for autonomous deployment.

## 5. Future Work

This study provides a strong foundation for further exploration of LLM applications in subsequent stages of the compliance workflow. Our future work will focus on extending this study to other stages of a compliance workflow encompassing critical activities such as preparation of audit working papers, evidence analysis, report generation, etc. This will enable us to study the potential of LLMs in greater detail.

We also plan to study mechanisms to address the key challenges identified in this study. We will focus on improving the completeness of outputs, mitigating hallucinations, and enhancing scalability.

Another important direction for future research can be the exploration of agent-based implementations of LLMs for cybersecurity compliance. As the research and the industrial community is scrambling to release the most intelligent agent, we have not yet come across such an implementation for cybersecurity compliance. Such implementations could potentially improve the scalability, adaptability, and efficiency of LLMs in complex compliance environments, addressing the limitations observed in this study.

## 6. Conclusion

This pilot study has demonstrated the potential of large language models (LLMs) to assist in the planning stage of the compliance workflow, covering activities such as SoA generation, audit objectives and scope definition, and checklist creation. Among the models tested, Sonnet 3.5 emerged as the most reliable, showcasing strong domain knowledge and the ability to generate relevant and complete outputs. However, challenges such as issues of completeness, hallucinations, and scalability highlight the need for further optimization and human oversight. Prompt engineering and data curation were critical to achieving reliable outputs. At the same time, we observed that LLMs can significantly reduce manual effort and provide skill coverage in compliance workflows.

Despite all these challenges, this study provides a strong foundation for future research. Extending the application of LLMs to subsequent steps of the compliance workflow offers significant potential to further explore LLM utilization in cybersecurity compliance tasks.

## Data Availability

The materials necessary to reproduce this work, including the hypothetical organizational context data, prompt templates, evaluation criteria, and raw model outputs, are available upon reasonable request to the corresponding author. Due to the ongoing nature of this research and potential future extensions, we have not yet published these materials in a public repository. However, we are committed to research transparency and will provide all necessary materials for verification of our results.

## AI Disclosure

Grok 3 was used for proofreading and LaTeX formatting assistance and the authors take full responsibility for the paper's content.



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

## References


[1] Salman, A., Creese, S., & Goldsmith, M. (2024, July). Position Paper: Leveraging Large Language Models for Cybersecurity Compliance. In 2024 *IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)* (pp. 496-503). IEEE.

[2] ISO. (2022). ISO/IEC 27001 standard – information security management systems. ISO. https://www.iso.org/standard/27001

[3] Free ISO27k Forum. (2025). Iso27001security.com. https://www.iso27001security.com/html/forum.html

[4] Theunissen, T., & Duijvesteijn, L. (2024). Using Large Language Models as a Road map for Establishing Core Values in a Legal Vacuum.

[5] Gushwork. (2024, October 17). Guide to Evaluating Large Language Models: Metrics and Best Practices. Composio. https://composio.dev/blog/llm-evaluation-guide/

[6] Orlando Amaral, Muhammad Ilyas Azeem, Sallam Abualhaija, and Lionel C Briand. Nlp-based automated compliance checking of data processing agreements against gdpr. *IEEE Transactions on Software Engineering*, 2023.

[7] Chenhao Tang, Zhengliang Liu, Chong Ma, Zihao Wu, Yiwei Li, Wei Liu, Dajiang Zhu, Quanzheng Li, Xiang Li, Tianming Liu, et al. Policygpt: Automated analysis of privacy policies with large language models. *arXiv preprint arXiv:2309.10238*, 2023

[8] Introducing Claude 3.5 Sonnet. (n.d.). www.anthropic.com. https://www.anthropic.com/news/claude-3-5-sonnet

[9] Meta. (2024). Introducing Llama 3.1: Our most capable models to date. Meta.com. https://ai.meta.com/blog/meta-llama-3-1/

[10] OpenAI. (2024). Hello GPT-4o. Openai.com. https://openai.com/index/hello-gpt-4o/

[11] Wang, B., Min, S., Deng, X., Shen, J., Wu, Y., Zettlemoyer, L., & Sun, H. (2022). Towards understanding chain-of-thought prompting: an empirical study of what matters. arXiv. *Preprint posted online on Dec, 20*.

[12] Gupta, S., Ranjan, R., & Singh, S. N. (2024). A Comprehensive Survey of Retrieval-Augmented Generation (RAG): Evolution, Current Landscape and Future Directions. *arXiv preprint arXiv:2410.12837*.

[13] Zhou, Y., Su, Y., Sun, Y., Wang, S., Wang, T., He, R., ... & Fang, Y. (2025). In-depth Analysis of Graph-based RAG in a Unified Framework. *arXiv preprint arXiv:2503.04338*.


## Appendix A. Detailed Results

Table 2 presents detailed results for Model Performance metrics across 18 experiments, whereas Table 3 presents detailed qualitative insights for Usefulness metrics. Both tables provide information of experiment scenarios and the data used.



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

TABLE 2. ORDINAL SCORING - MODEL PERFORMANCE METRICS

| Compliance Activity | Activity Scenario | Model | Data Used | Inference | Relevance | Completeness | Hallucinations |
|---|---|---|---|---|---|---|---|
| SoA Generation | Simple Query | ChatGPT 4o | Network Diagram & Asset Register | 3 | 1 | 2 | 3 |
| | | Sonnet 3.5 | Network Diagram & Asset Register | 3 | 3 | 1 | 3 |
| | | Llama 3.1 405B | Asset Register | 2 | 1 | 0 | 3 |
| | Change absorption with increasing change | ChatGPT 4o | Connected experiment with above | 3 | 1 | 3 | 3 |
| | | Sonnet 3.5 | Connected experiment with above | 3 | 3 | 3 | 3 |
| | | Llama 3.1 405B | Connected experiment with above | 3 | 3 | 3 | 3 |
| Scope, Obj and Plan | Simple Query | ChatGPT 4o | Organizational Context, Network Diagram & Asset Register | 3 | 1 | 3 | 2 |
| | | Sonnet 3.5 | Organizational Context, Network Diagram & Asset Register | 3 | 3 | 3 | 3 |
| | | Llama 3.1 405B | Organizational Context, Network Diagram & Asset Register | 2 | 3 | 3 | 2 |
| | Change absorption | ChatGPT 4o | Organizational Context, Network Diagram & Asset Register | 3 | 1 | 3 | 2 |
| | | Sonnet 3.5 | Organizational Context, Network Diagram & Asset Register | 3 | 3 | 3 | 3 |
| | | Llama 3.1 405B | Organizational Context, Network Diagram & Asset Register | 2 | 3 | 3 | 3 |
| Checklist Generation | Simple Query | ChatGPT 4o | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | 3 | 2 | 1 | 3 |
| | | Sonnet 3.5 | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | 3 | 3 | 3 | 3 |
| | | Llama 3.1 405B | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | 2 | 2 | 1 | 3 |
| | Step by Step response generation | ChatGPT 4o | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | 3 | 2 | 2 | 2 |
| | | Sonnet 3.5 | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | 3 | 3 | 3 | 3 |
| | | Llama 3.1 405B | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | 2 | 3 | 2 | 3 |



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.

TABLE 3. QUALITATIVE ASSESSMENT - USEFULNESS METRIC

| Compliance Activity | Activity Scenario | Model | Data Used | Change absorption | Scalability | Covers skill gap |
|---|---|---|---|---|---|---|
| SoA Generation | Simple Query | ChatGPT 4o | Network Diagram & Asset Register | - | - | Yes |
| | | Sonnet 3.5 | Network Diagram & Asset Register | - | - | Yes |
| | | Llama 3.1 405B | Asset Register | - | - | Yes |
| | Change absorption with increasing change | ChatGPT 4o | Connected experiment with 2 | Yes | Needs further study | Yes |
| | | Sonnet 3.5 | Connected experiment with 3 | Yes | Needs further study | Yes |
| | | Llama 3.1 405B | Connected experiment with 4 | Yes | Needs further study | Yes |
| Scope, Obj and Plan | Simple Query | ChatGPT 4o | Organizational Context, Network Diagram & Asset Register | - | - | Yes |
| | | Sonnet 3.5 | Organizational Context, Network Diagram & Asset Register | - | - | Yes |
| | | Llama 3.1 405B | Organizational Context, Network Diagram & Asset Register | - | - | Yes |
| | Change absorption | ChatGPT 4o | Organizational Context, Network Diagram & Asset Register | Yes | - | Yes |
| | | Sonnet 3.5 | Organizational Context, Network Diagram & Asset Register | Yes | - | Yes |
| | | Llama 3.1 405B | Organizational Context, Network Diagram & Asset Register | Yes | - | Yes |
| Checklist Generation | Simple Query | ChatGPT 4o | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | - | - | Yes |
| | | Sonnet 3.5 | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | - | - | Yes |
| | | Llama 3.1 405B | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | - | - | Yes |
| | Step by Step response generation | ChatGPT 4o | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | - | - | Yes |
| | | Sonnet 3.5 | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | - | - | Yes |
| | | Llama 3.1 405B | Detailed Org Context with list of Policy Documents, Basic Risk Register, Asset Register, ISO 27001 Sample Questions | - | - | Yes |



Authorized licensed use limited to: Atlantic Technological University (ATU). Downloaded on October 13,2025 at 18:59:35 UTC from IEEE Xplore. Restrictions apply.